

James Forshaw
Off-by-One
2025

Who am I?



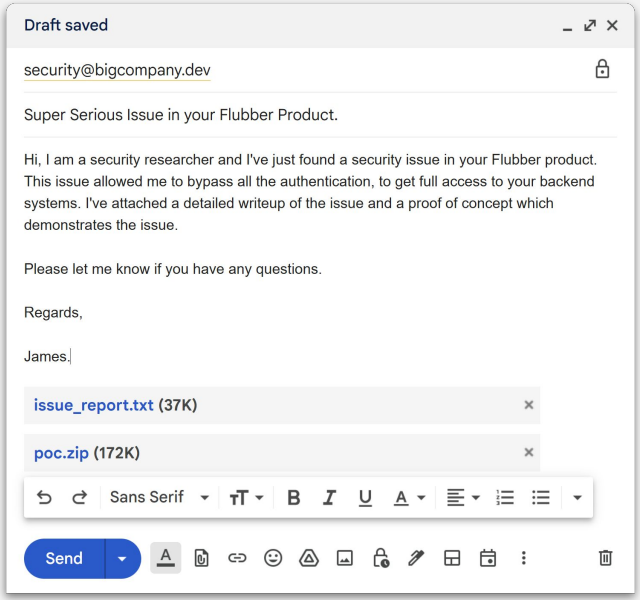
- Researcher @ Google Project Zero
- Specialize in Windows
- Writer of tools and books.

“Never met a logical vulnerability I didn’t like.”

The Idyllic Life of a Security Researcher



Finding



Reporting



Chilling

The all too Real Life of a Security Researcher



Finding

Bob Smith 09:52 (6 minutes ago)

to me

We don't think this is really a security issue. If you can demonstrate impact then maybe we'll talk about it, can you do some additional unpaid work for our mega-corp to verify this is a real issue?

Thanks,

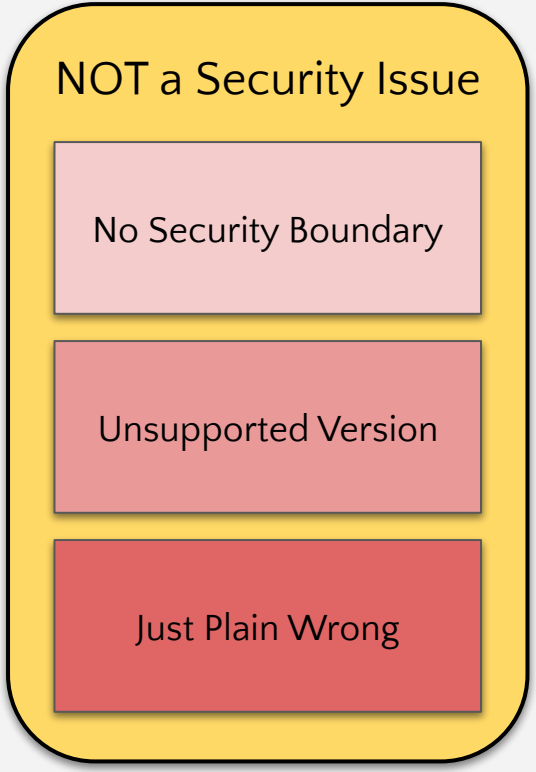
Bob Smith
(Head of Security, Big Company LLC)

Reporting

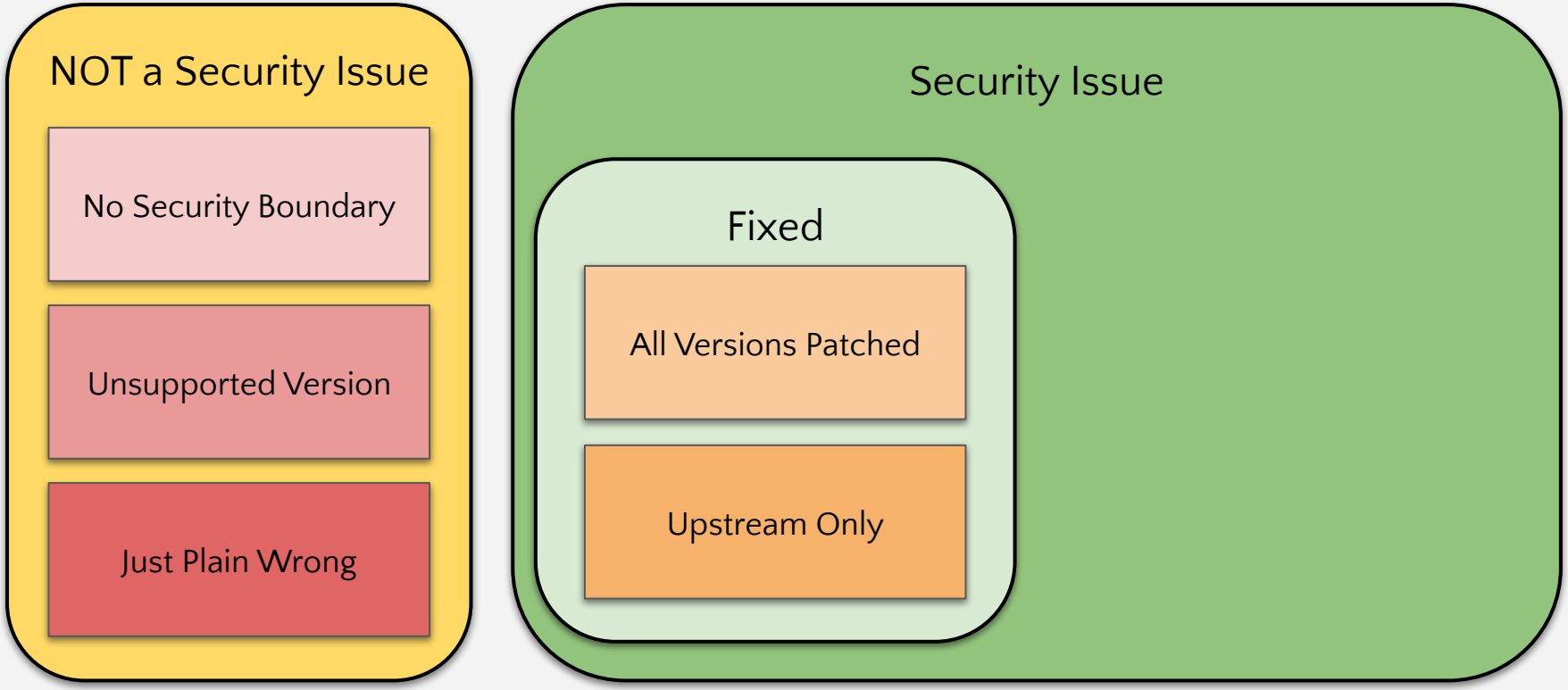


WTF?

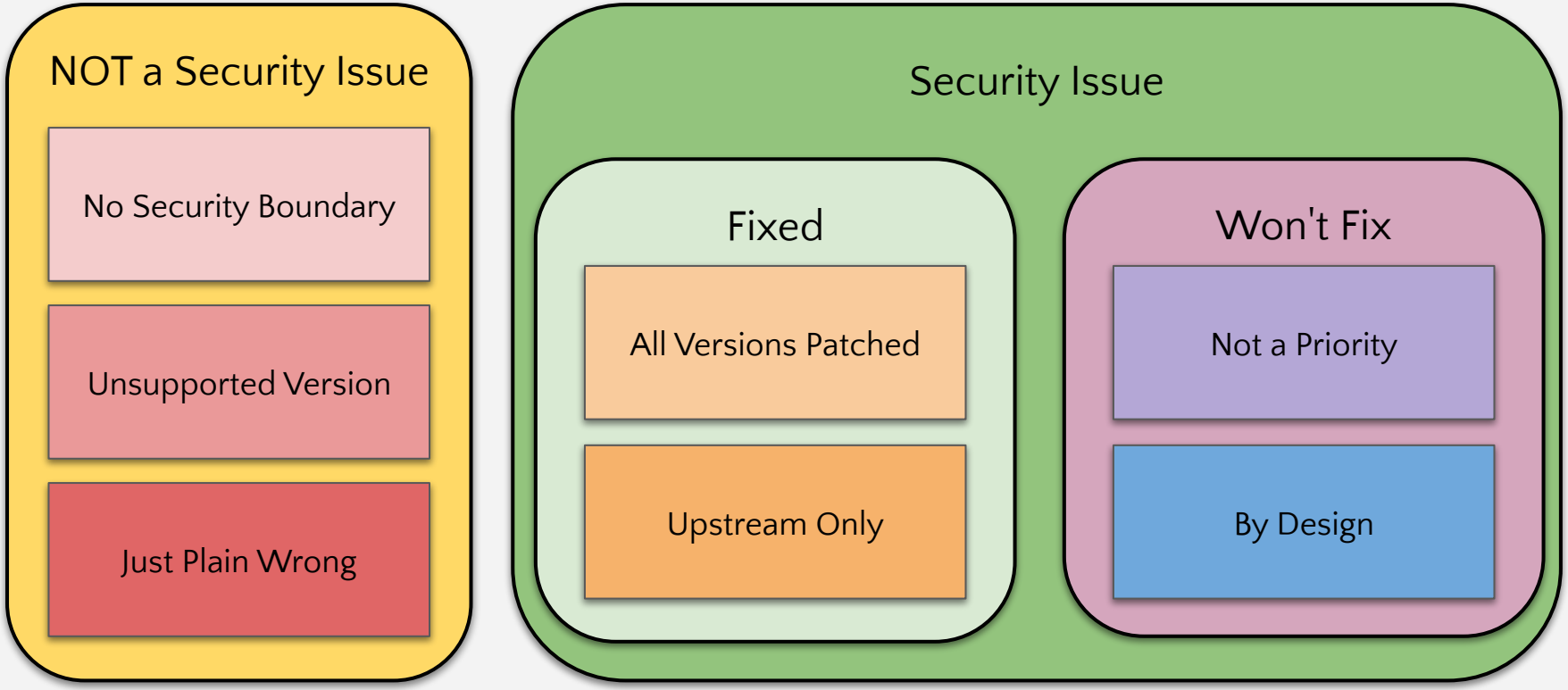
Outcome of Reporting



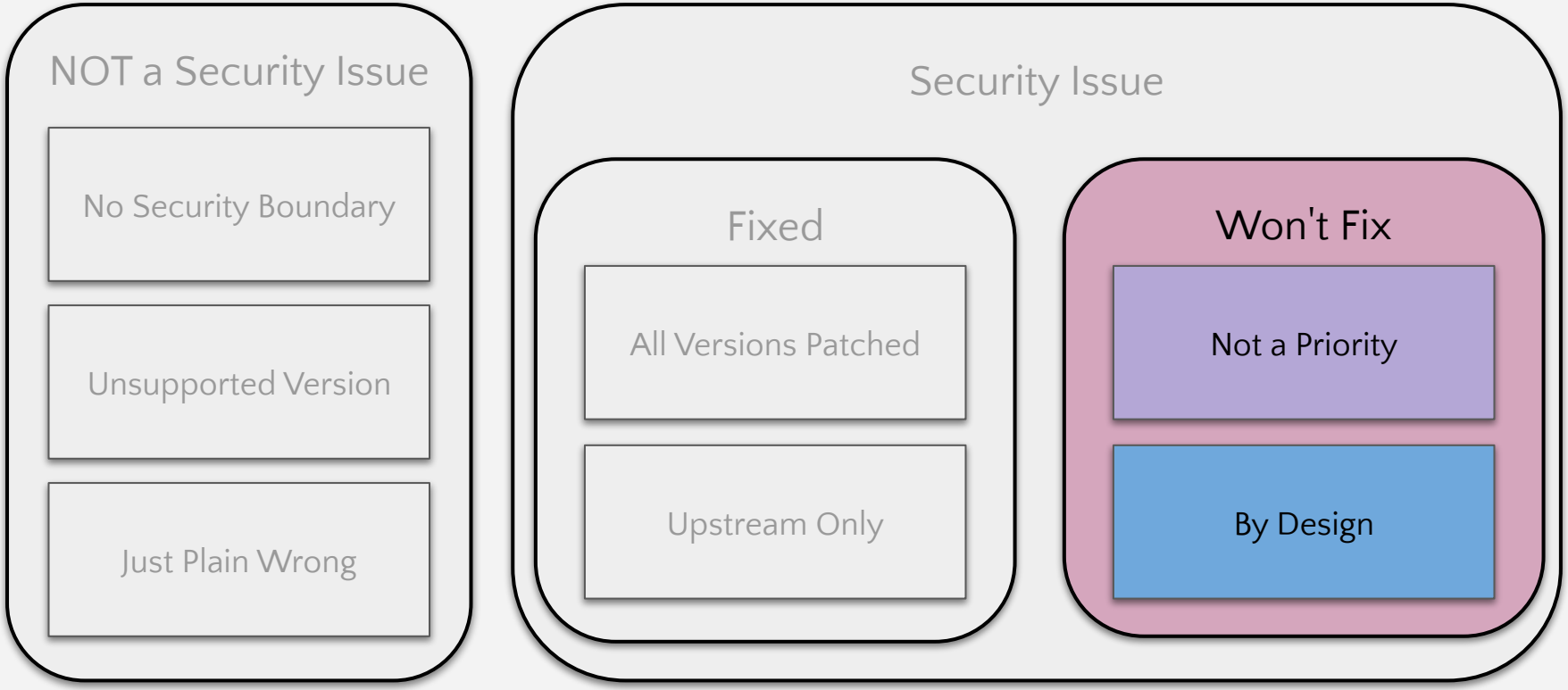
Outcome of Reporting



Outcome of Reporting



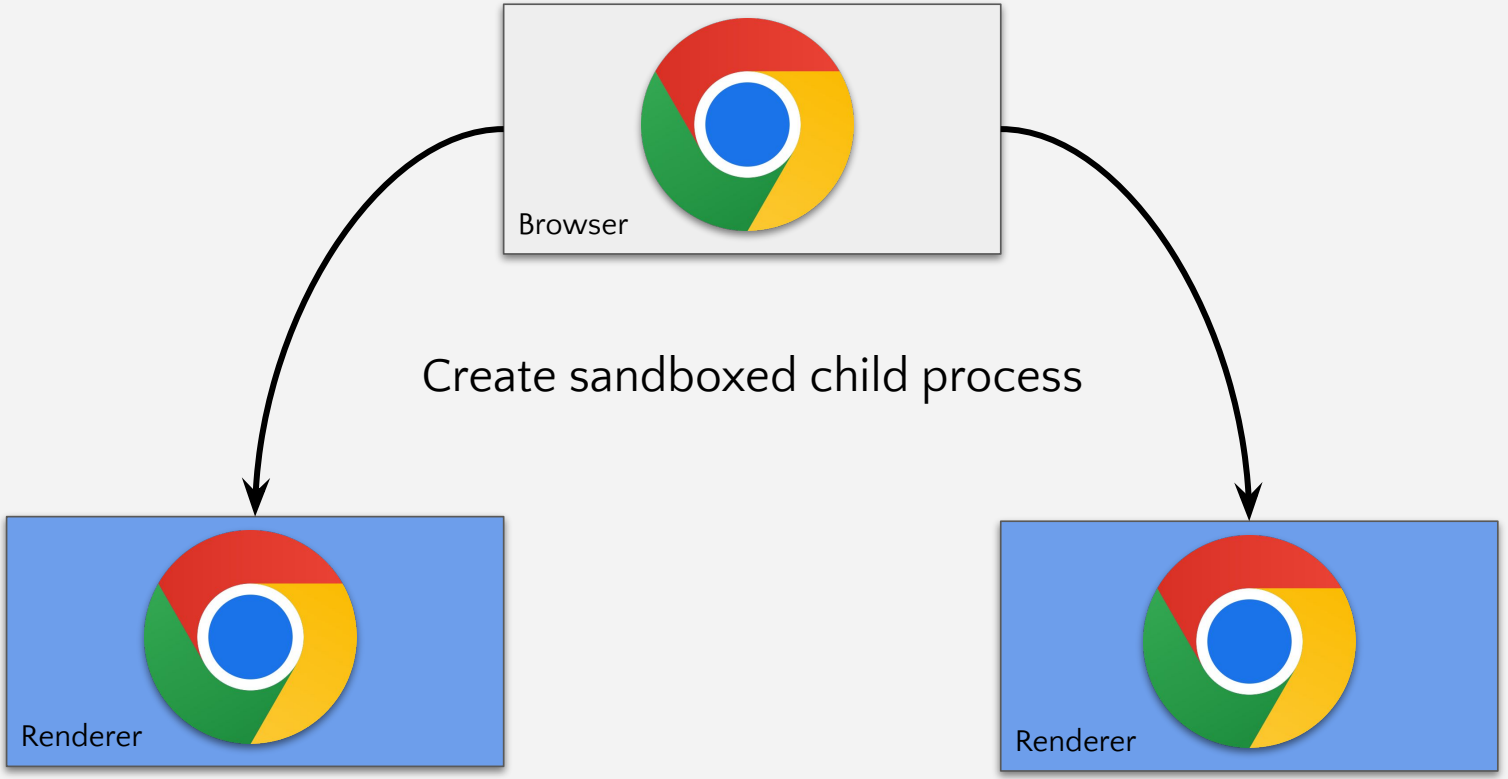
Outcome of Reporting



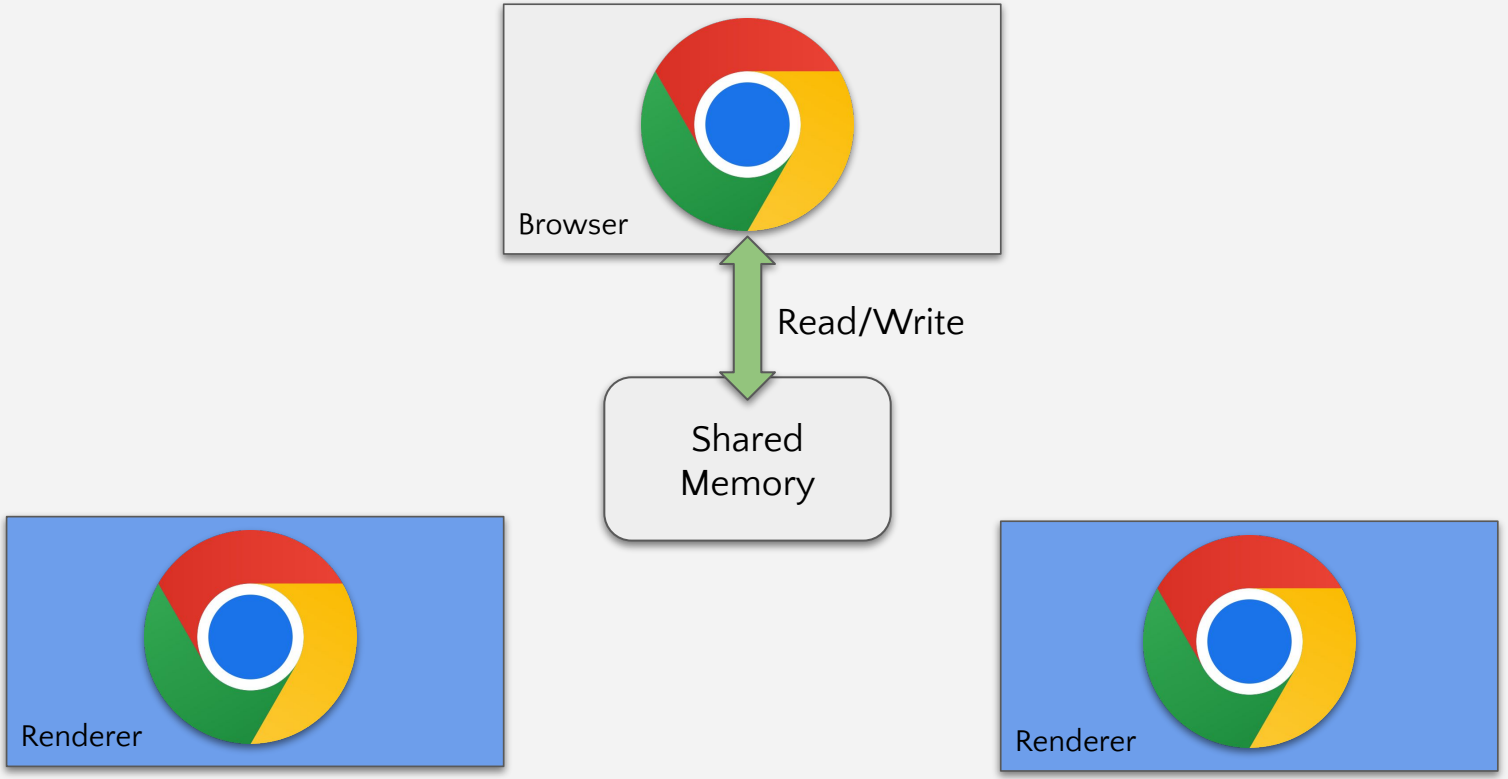
Real-World Example: Chrome Windows Shared Memory Vulnerability

https://issues.chromium.org/issues/40078787

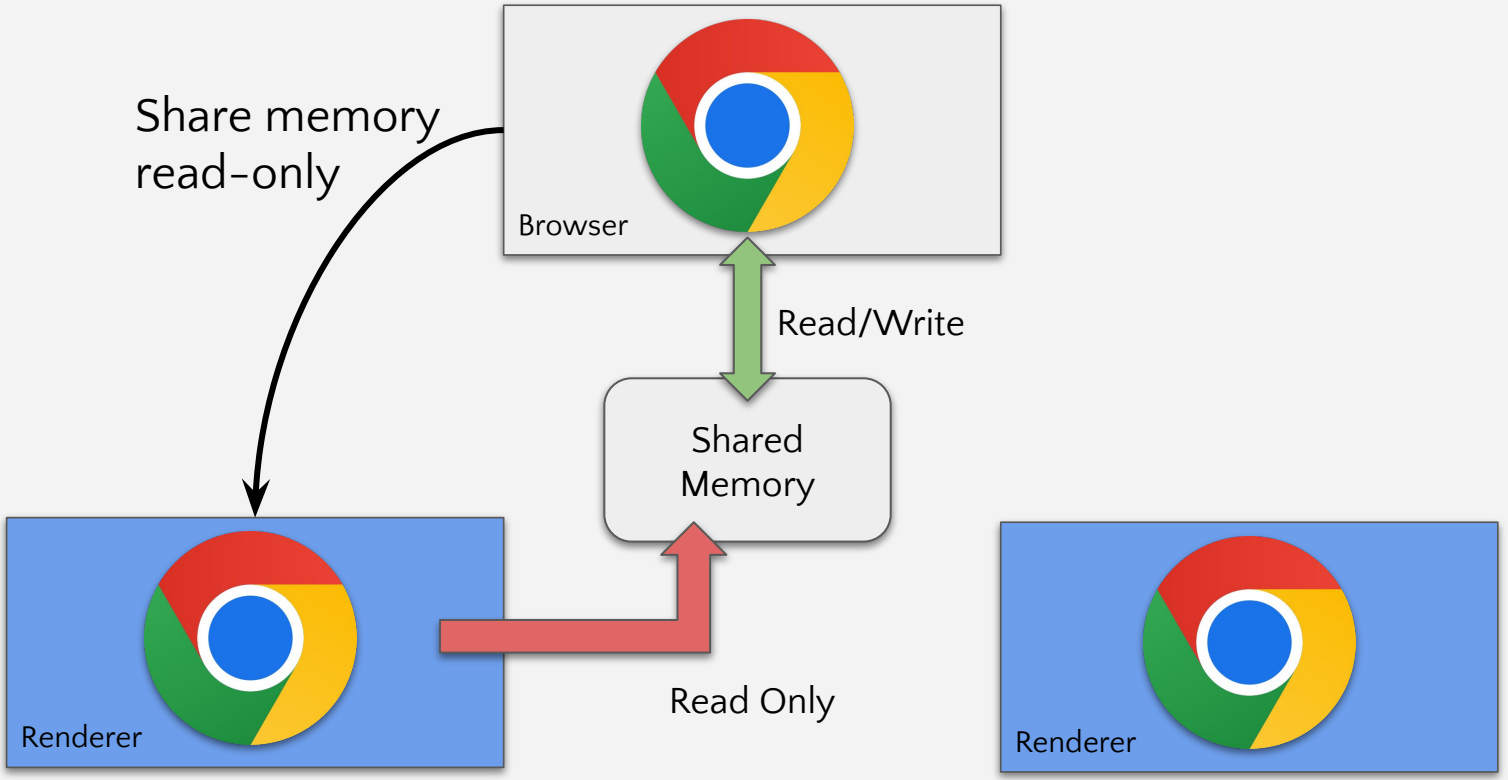
Chrome Shared Memory



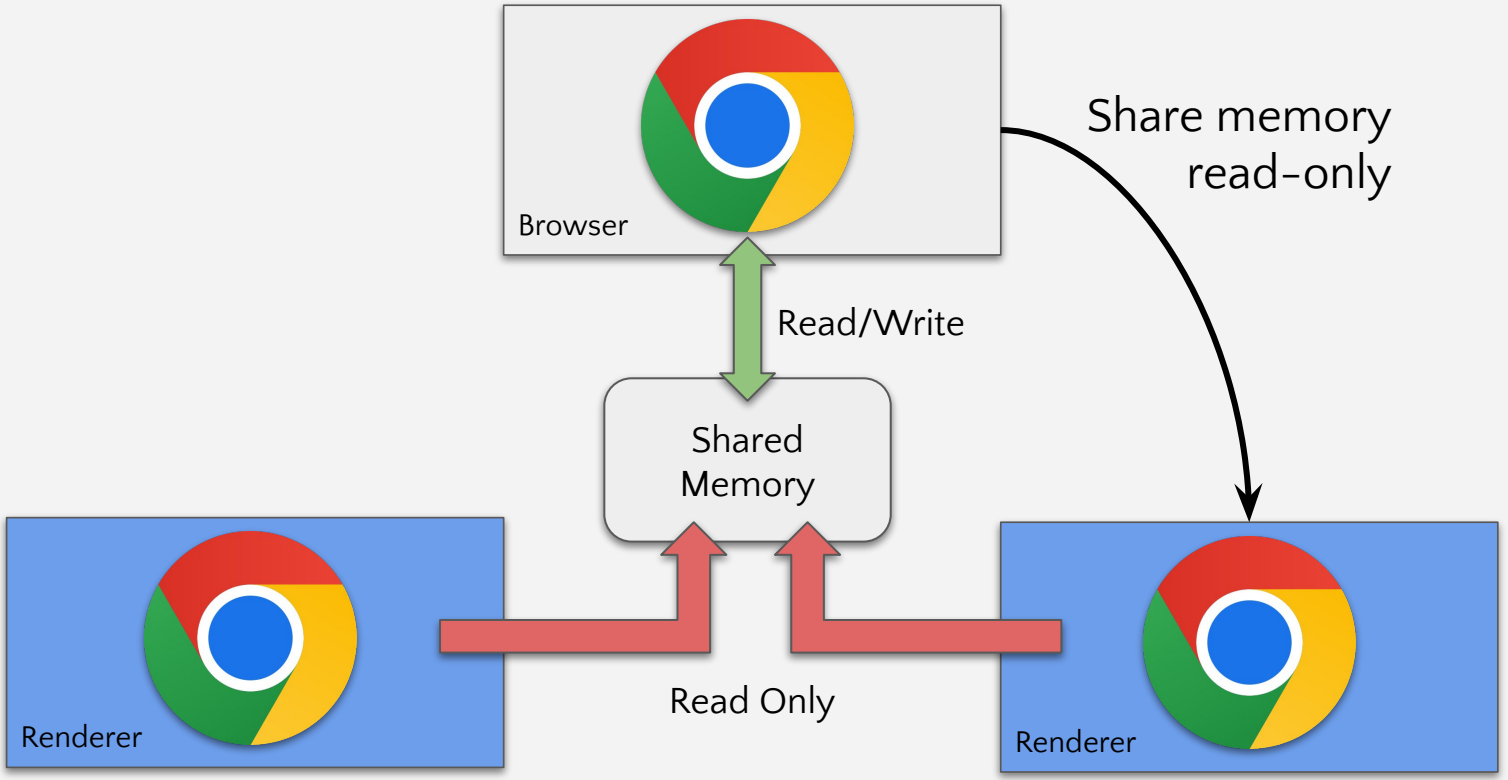
Chrome Shared Memory



Chrome Shared Memory



Chrome Shared Memory



Sharing a Section Handle on Windows

```
bool SharedMemory::ShareToProcessCommon(ProcessHandle process,
                                        SharedMemoryHandle *new_handle) {
  DWORD access = FILE_MAP_READ;
  HANDLE mapped_file = mapped_file_;
  HANDLE result;
  if (!read_only_)
    access |= FILE_MAP_WRITE;
  if (!DuplicateHandle(GetCurrentProcess(), mapped_file, process,
      &result, access, FALSE, 0))
    return false;
  *new_handle = result;
  return true;
}
```

Default to read permissions

Sharing a Section Handle on Windows

```
bool SharedMemory::ShareToProcessCommon(ProcessHandle process,
                                        SharedMemoryHandle *new_handle) {
  DWORD access = FILE_MAP_READ;
  HANDLE mapped_file = mapped_file_;
  HANDLE result;
  if (!read_only_)
    access |= FILE_MAP_WRITE;
  if (!DuplicateHandle(GetCurrentProcess(), mapped_file, process,
      &result, access, FALSE, 0))
    return false;
  *new_handle = result;
  return true;
}
```

If not read-only
then also add
write access

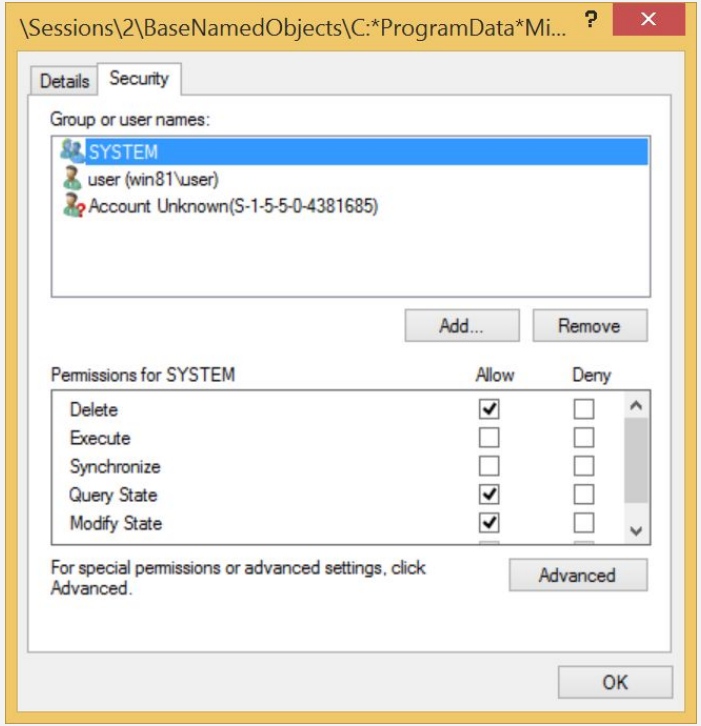
Sharing a Section Handle on Windows

```
bool SharedMemory::ShareToProcessCommon(ProcessHandle process,
                                        SharedMemoryHandle *new_handle) {
  DWORD access = FILE_MAP_READ;
  HANDLE mapped_file = mapped_file_;
  HANDLE result;
  if (!read_only_)
    access |= FILE_MAP_WRITE;
  if (!DuplicateHandle(GetCurrentProcess(), mapped_file, process,
      &result, access, FALSE, 0))
    return false;
  *new_handle = result;
  return true;
}
```

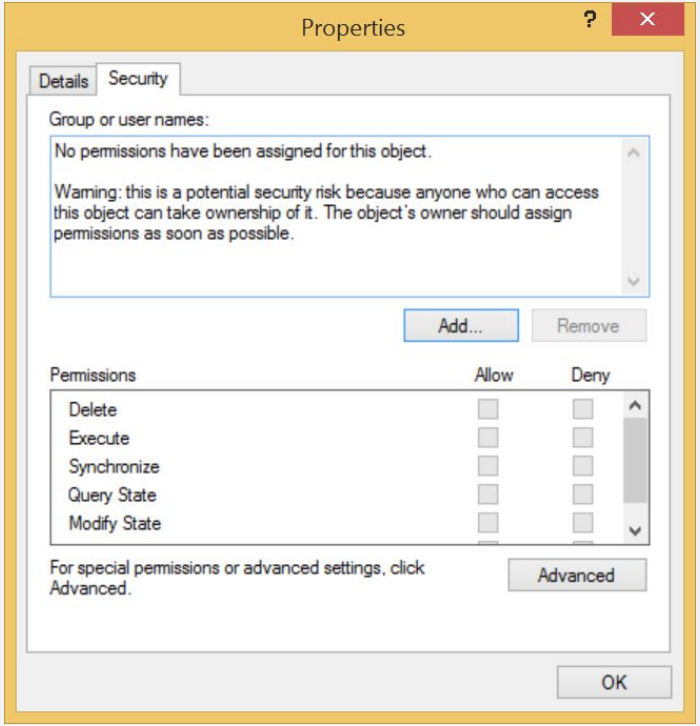


So what's the problem?

Named Section

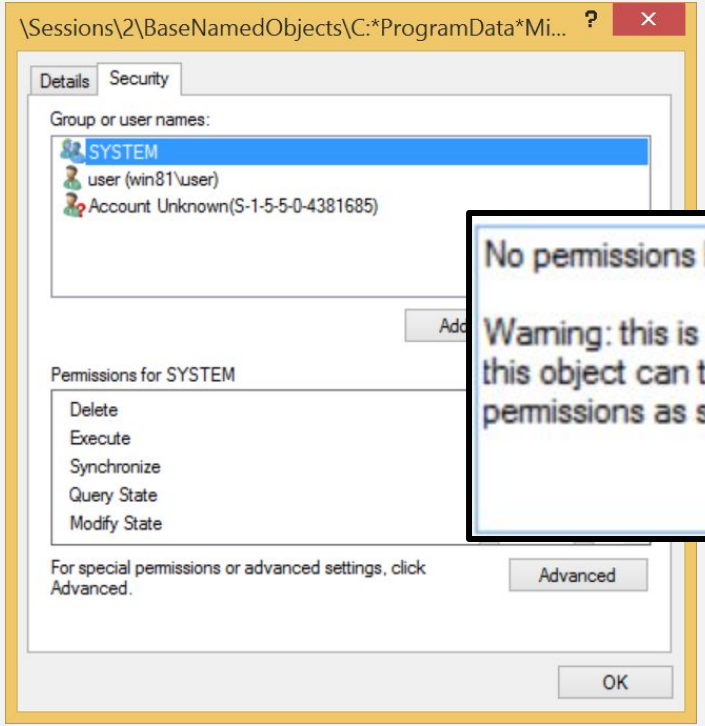


Unnamed Section

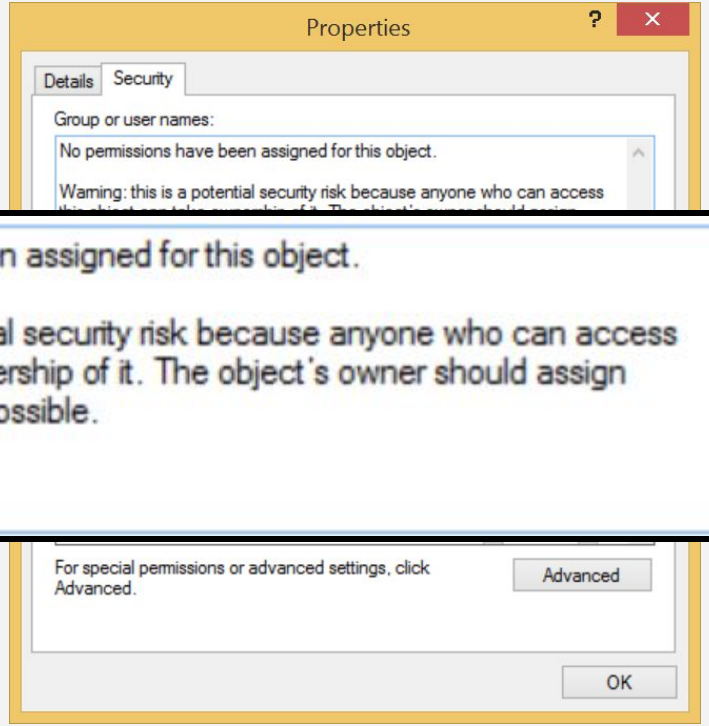


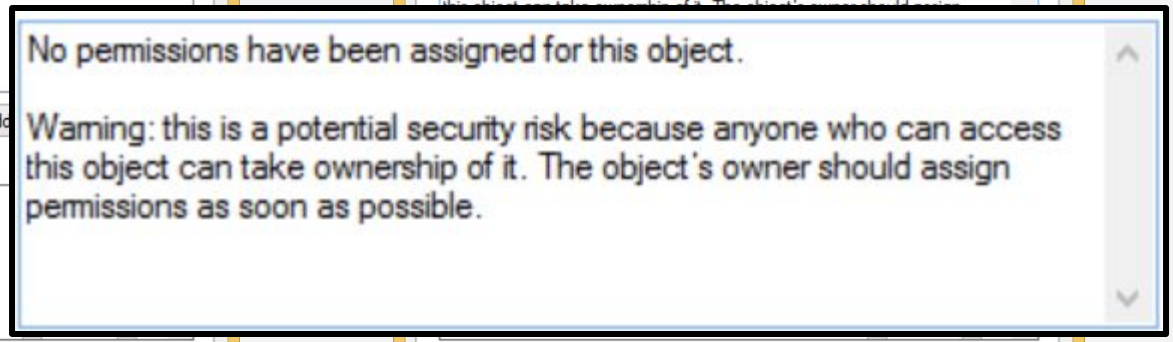
So what's the problem?

Named Section

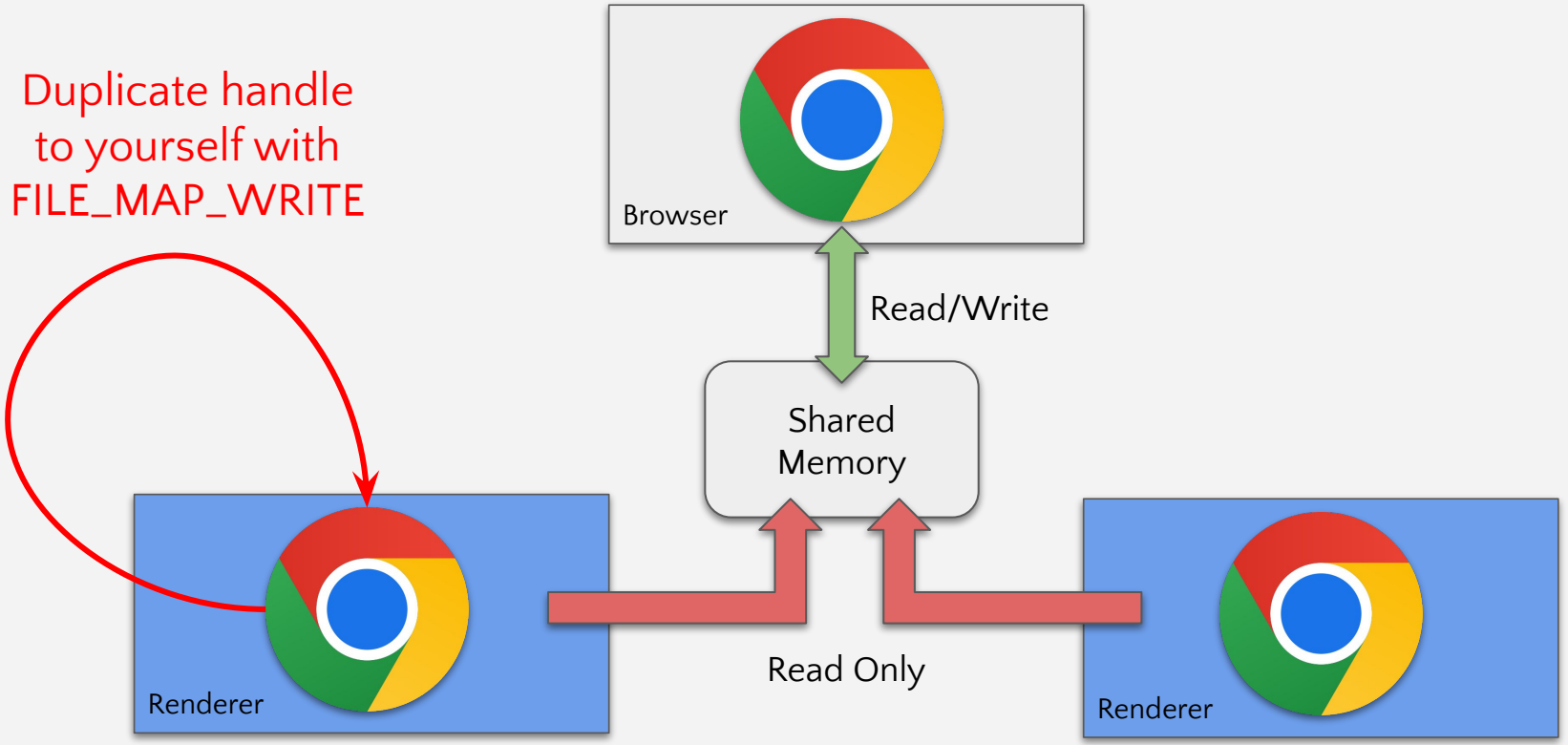


Unnamed Section

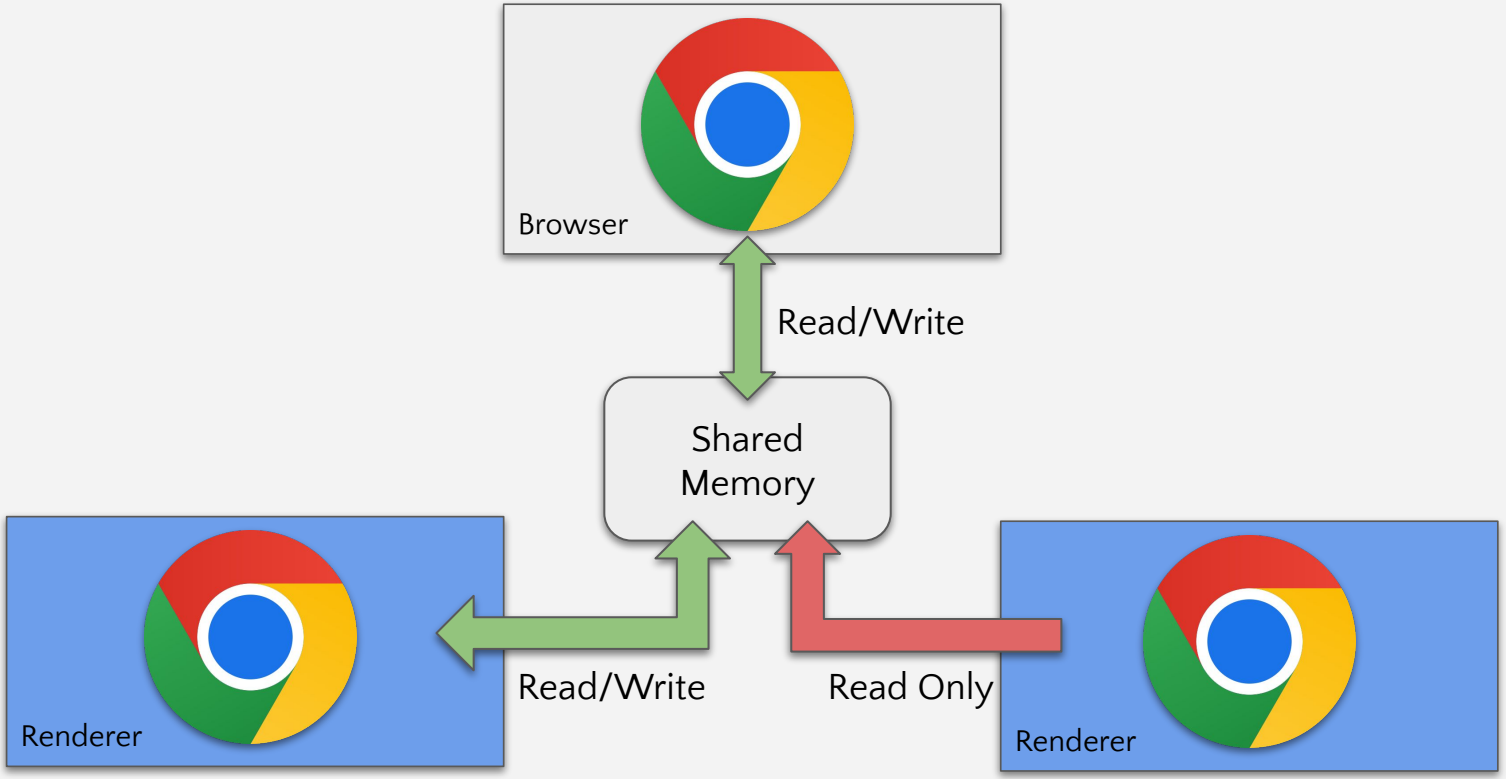




Exploiting the Issue



Exploiting the Issue



Bug was reported, and?



Justin Schuh <jschuh@chromium.org> #24

Feb 15, 2014 07:40PM

This really isn't medium. We need to fix it because in the future we will rely on enforcing things like read-only memory, but today we shouldn't be. So, bumping down to low-severity (just in case I missed something).

I guess I'll fix it myself!



Step 1:
Get a job at Google!

I guess I'll fix it myself!



Step 1:
Get a job at Google!



Step 2:
Find a read-only section

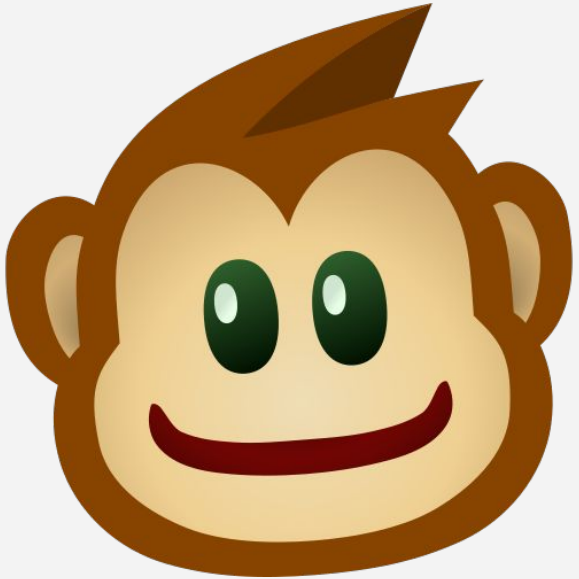
I guess I'll fix it myself!



Step 1:
Get a job at Google!



Step 2:
Find a read-only section



Step 3:
Exploit it then fix it

GreaseMonkey / Content / User Scripts

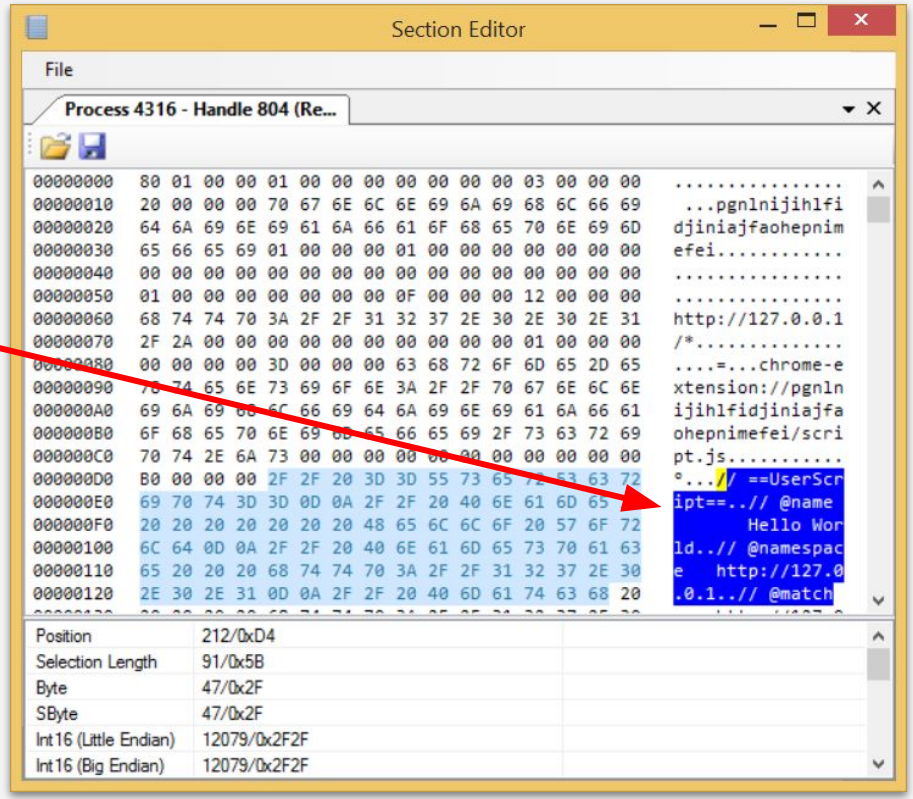
```
// ==UserScript==
// @name         Hello World
// @namespace http://127.0.0.1
// @match      http://127.0.0.1/*
// @version    1
// ==/UserScript==
alert("hello world");
```

URI match

Script to inject

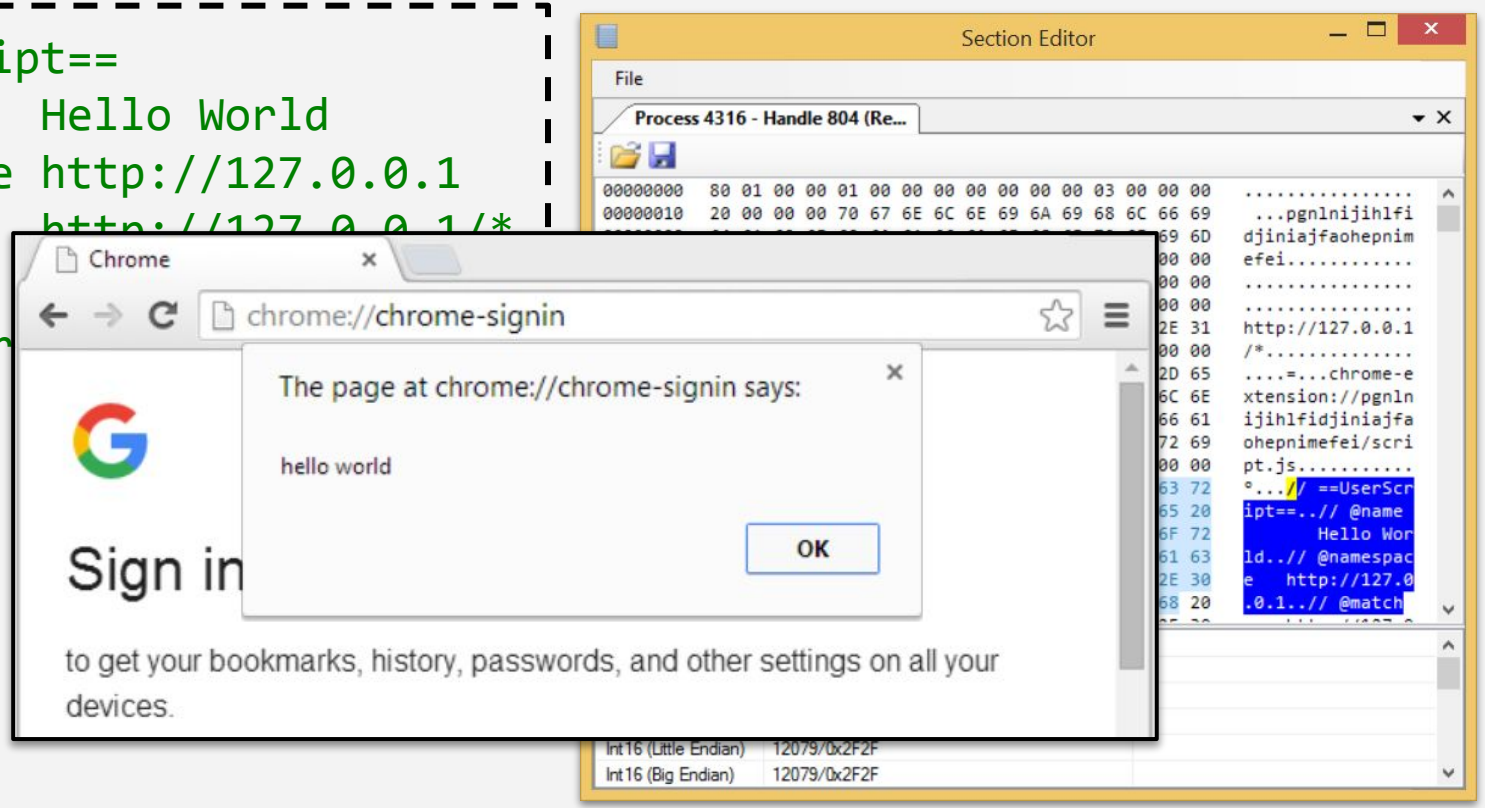
GreaseMonkey / Content / User Scripts

```
// ==UserScript==
// @name         Hello World
// @namespace http://127.0.0.1
// @match      http://127.0.0.1/*
// @version    1
// ==/UserScript==
alert("hello world");
```



GreaseMonkey / Content / User Scripts

```
// ==UserScript==
// @name         Hello World
// @namespace http://127.0.0.1
// @match
// @version
// ==/UserScr
alert("hello
```



The Bug is Fixed

Project Zero

News and updates from the Project Zero team at Google

Monday, October 20, 2014

Did the “Man With No Name” Feel Insecure?

Posted by James Forshaw, Taker of Names

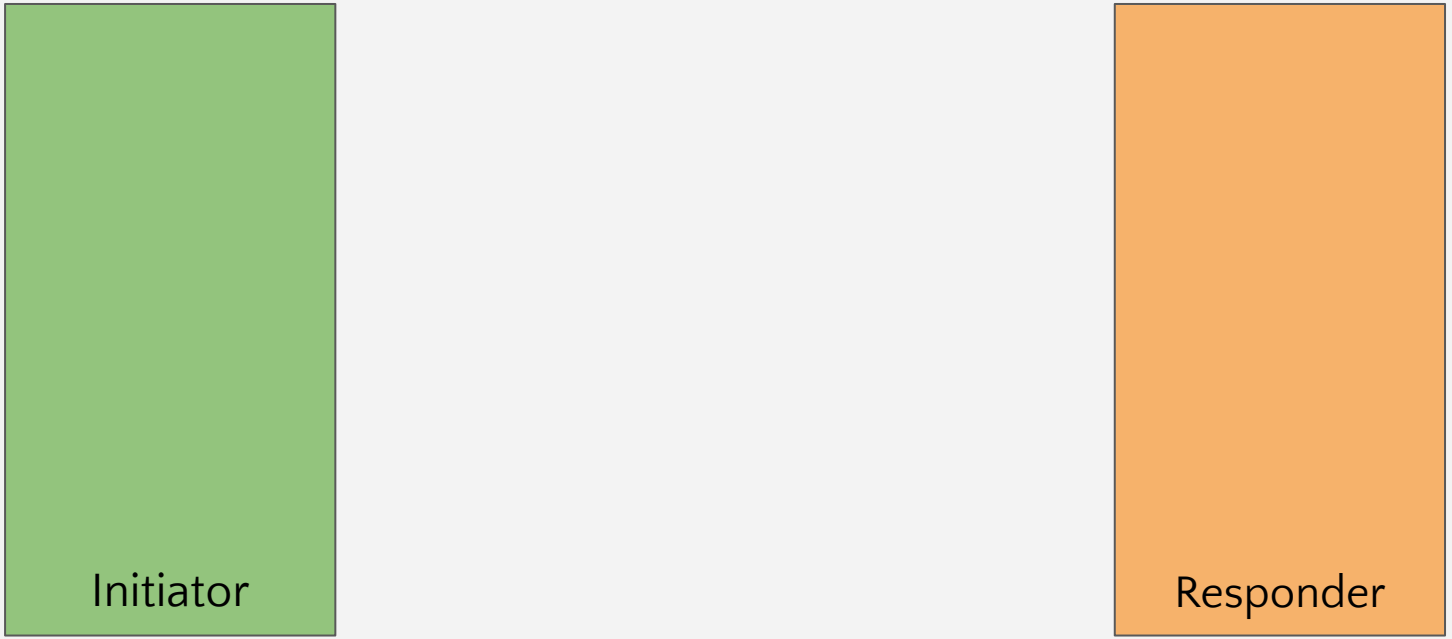
Sometimes when I'm doing security research I'll come across a bug which surprises me. I discovered just such a bug in the Windows version of Chrome which exposed a little-known security detail in the OS. The bug, CVE-2014-3196 was fixed in M38, so it seemed a good time for a blog post. The actual reported issue is here. While the bug didn’t allow for a full sandbox escape it did provide the initial part of a chain; something that’s still important to fix.

https://googleprojectzero.blogspot.com/2014/10/

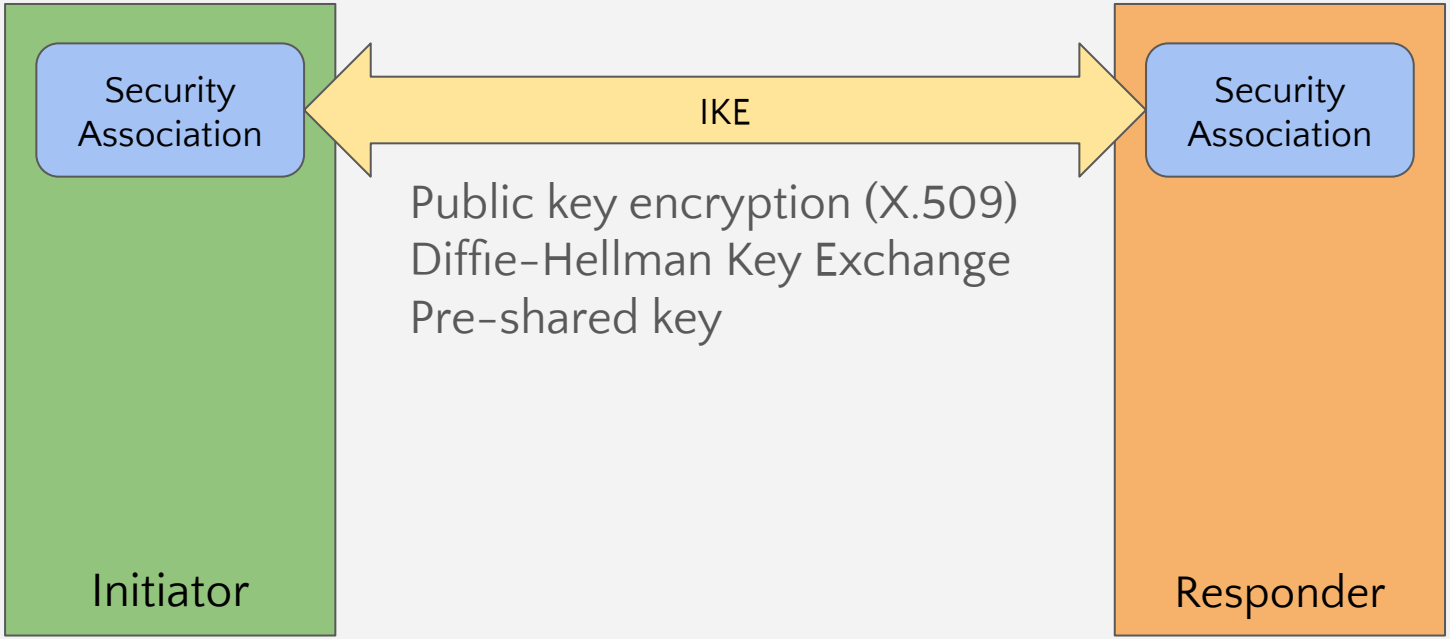
Real-World Example: IKEEXT AuthIP Unvalidated GSS_ID

https://project-zero.issues.chromium.org/issues/42451333

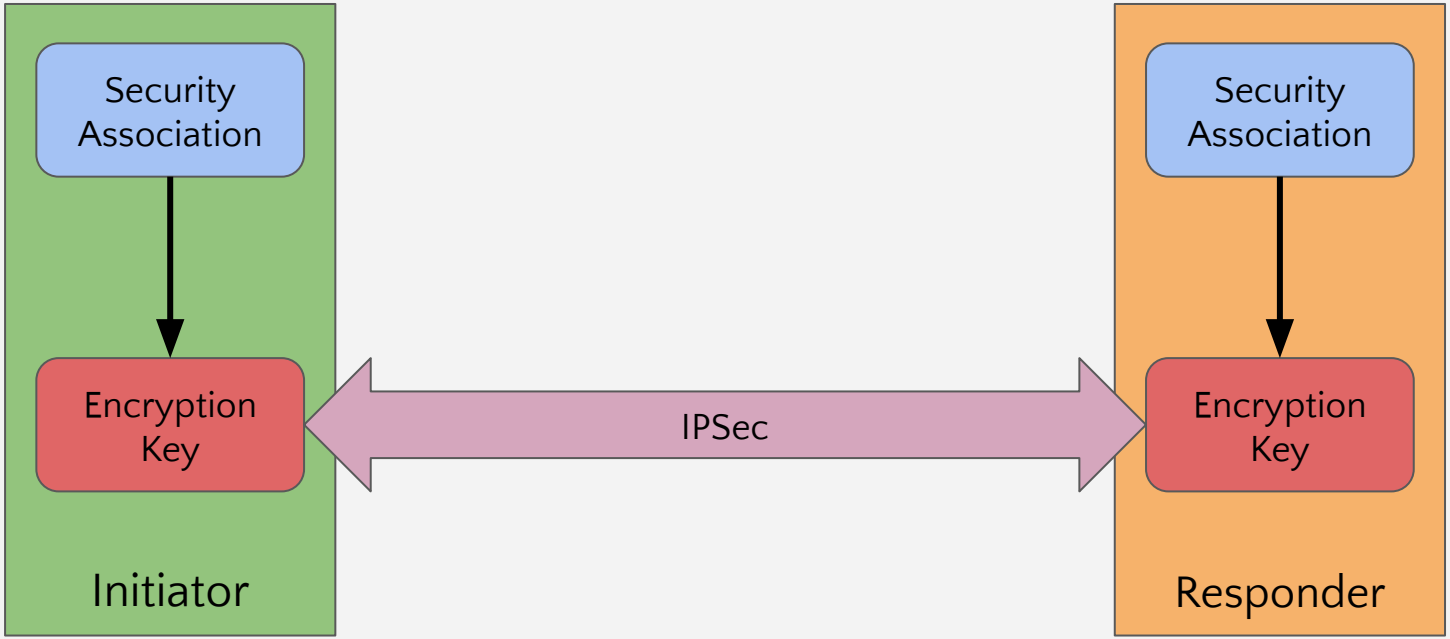
IPSec and Internet Key Exchange Protocol (IKE)



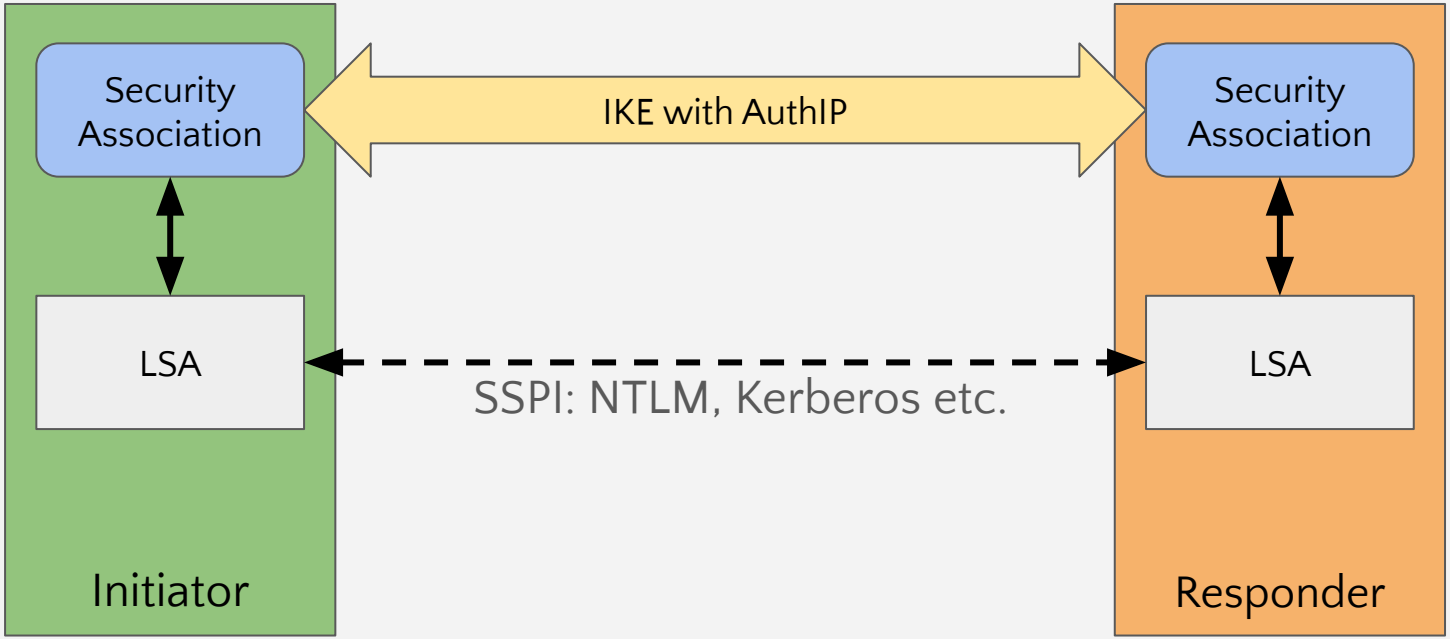
IPSec and Internet Key Exchange Protocol (IKE)



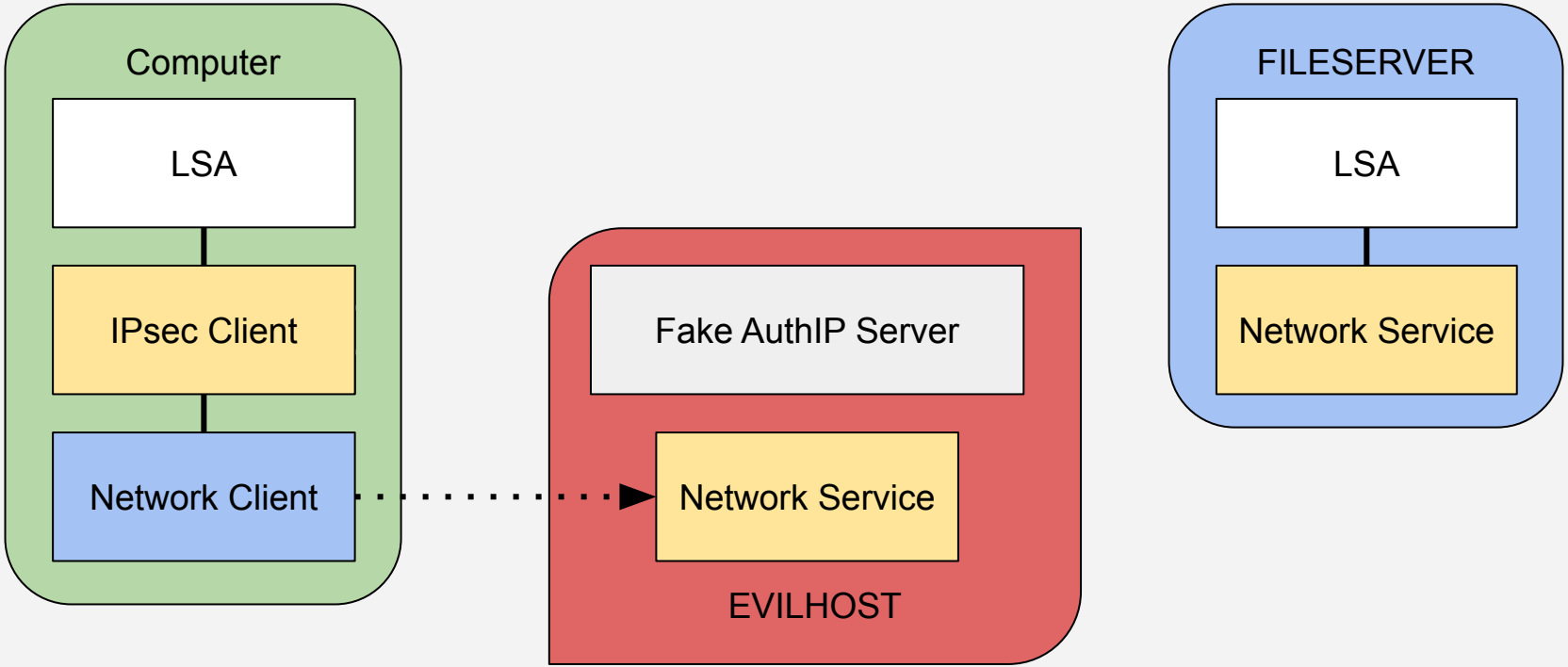
IPSec and Internet Key Exchange Protocol (IKE)



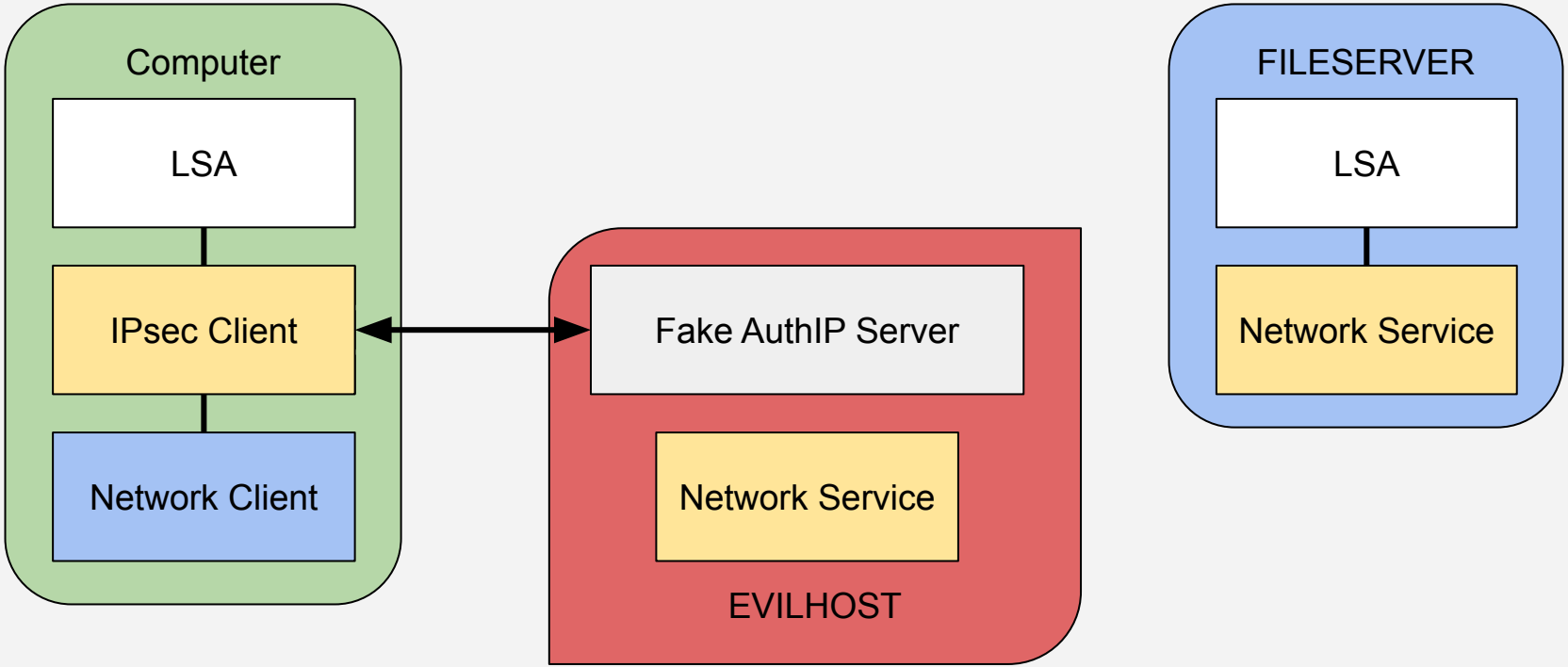
Authenticated Internet Protocol (AuthIP)



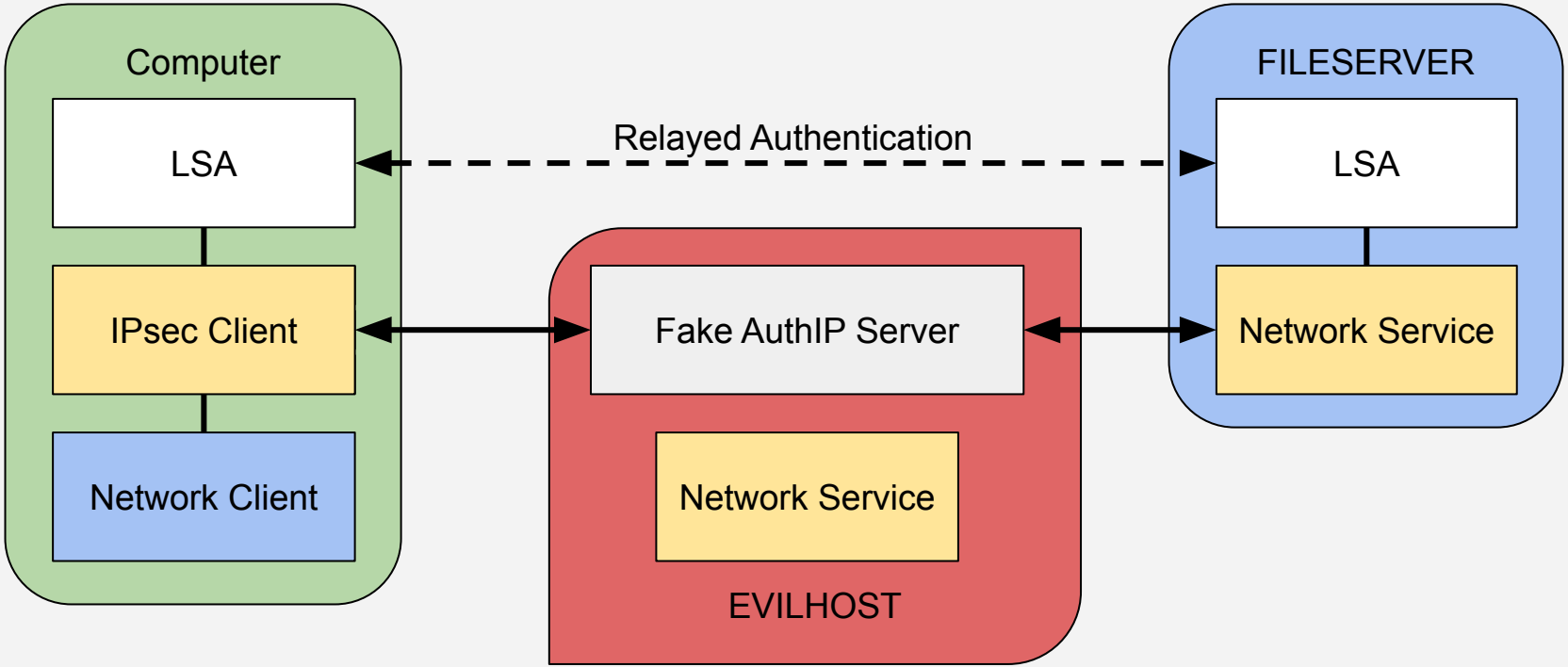
Relaying AuthIP Authentication



Relaying AuthIP Authentication



Relaying AuthIP Authentication



Relaying AuthIP Authentication

KB5005413: Mitigating NTLM Relay Attacks on Active Directory Certificate Services (AD CS)

Summary

Microsoft is aware of PetitPotam which can potentially be used to attack Windows domain controllers or other Windows servers. PetitPotam is a classic NTLM Relay Attack, and such attacks have been previously documented by Microsoft along with numerous mitigation options to protect customers. For example: Microsoft Security Advisory 974926.

Relaying AuthIP Authentication

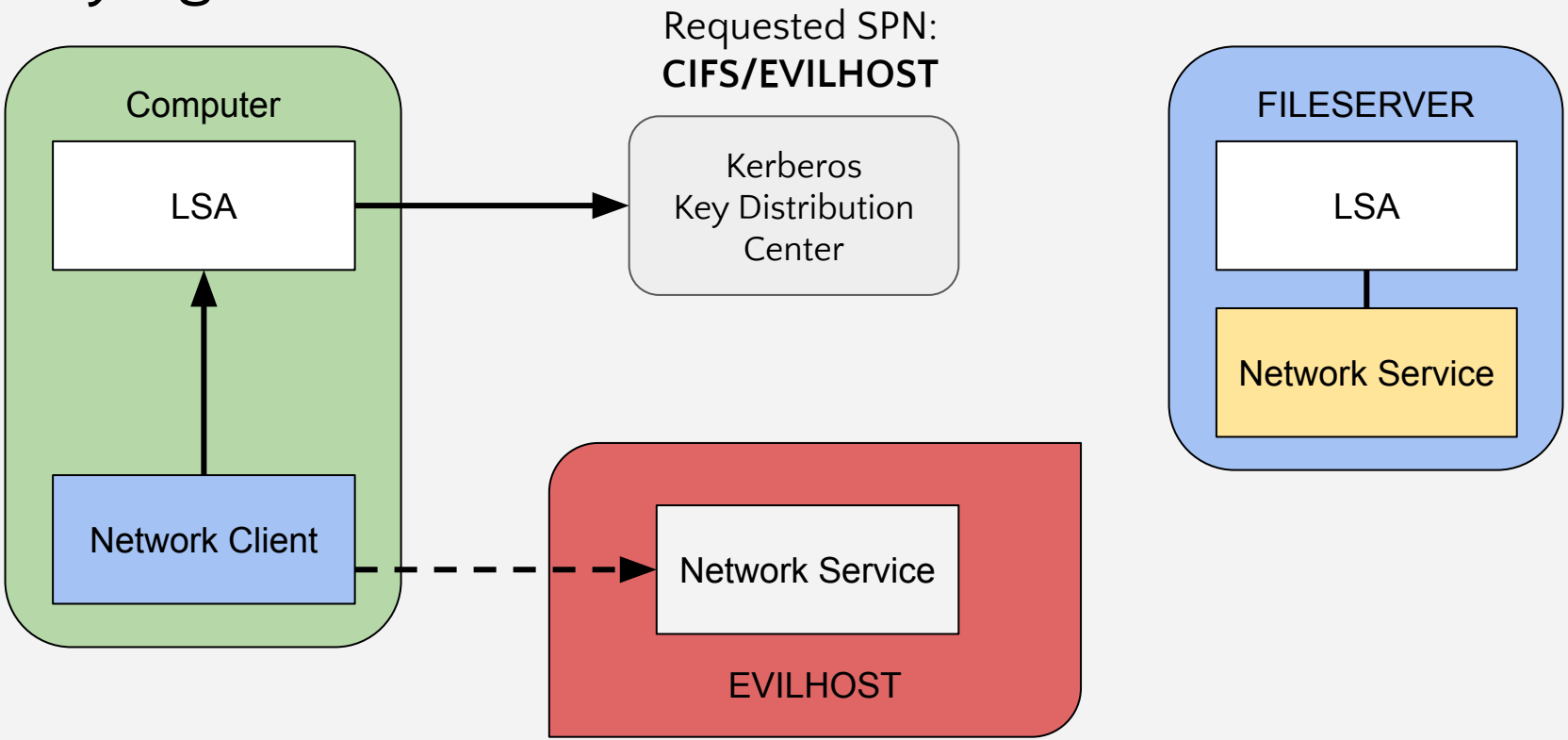
KB5005413: Mitigating NTLM Relay Attacks on Active Directory Certificate

Additional mitigation

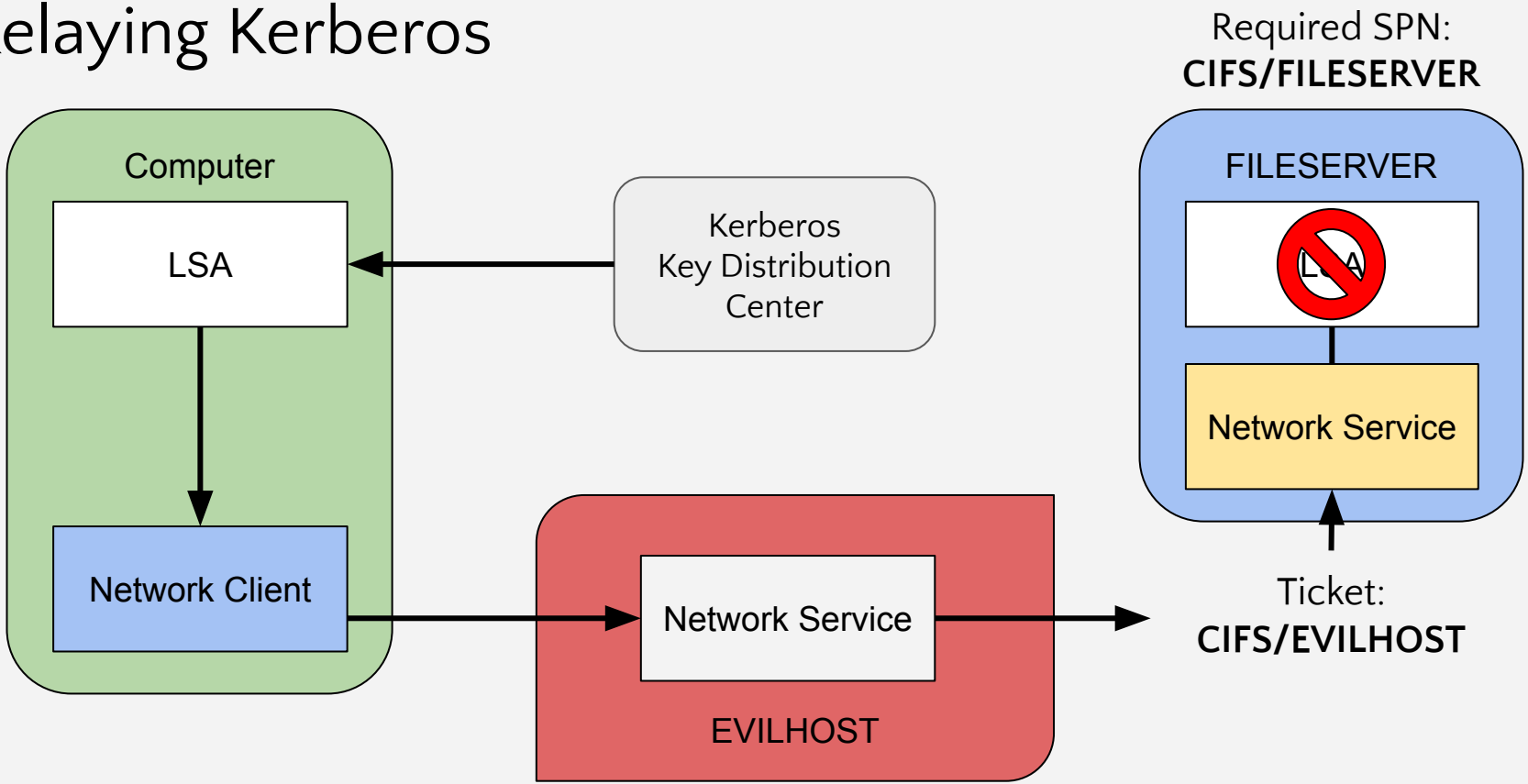
In addition to the primary mitigations, we recommend you disable NTLM authentication where possible. The following mitigations are listed in order from more secure to less secure:

- Disable NTLM Authentication on your Windows domain controller. This can be accomplished by following the documentation in Network security: Restrict NTLM: NTLM authentication in this domain.

Relaying Kerberos



Relaying Kerberos



Exchanging the Security Principal Name (SPN)

2.2.3.3 GSS_ID 0x86 Payload Packet

Article • 04/23/2024

Feedback

In IKEv1, the identity information is passed between peers as an attribute of the security association (SA) in the form of an identity payload, as specified in [RFC2408] section 3.8. In the Authenticated Internet Protocol, a separate payload is used to convey identity information in the form of a security principal name.

The following diagram shows the GSS_ID 0x86 payload packet structure.

Set to CIFS/FILESERVER

Expand table

0	1	2	3	4	5	6	7	8	9	10	11	12	13	14	15	16	17	18	19	20	21	22	23	24	25	26	27	28	29	30	31
Security Principle Name (variable)																															
...																															

Reported, and...



James Forshaw <forshaw@google.com> #3 Oct 5, 2021 08:50AM

Status: Won't Fix (Obsolete)

MSRC have indicated that this issue does not meet the bar for a security bulletin. It's considered to be 'Moderate: Spoofing'. To meet the bar it must be at least 'Important' severity. The general rationale is that network protocols where the server can influence the SPN used for authentication to be Moderate if there's no control over the user being used for authentication. If the user can be directly influenced to authenticate, such as in the PetitPotam technique, that will be considered Important and fixed. However, yhey will consider this issue for a vNext fix.

Additionally Microsoft consider AuthIP using Windows authentication to be deprecated and recommend moving to IKEv2 or AuthIP with certificate authentication instead.

No One Cares, to the Blogs.

Wednesday, October 20, 2021

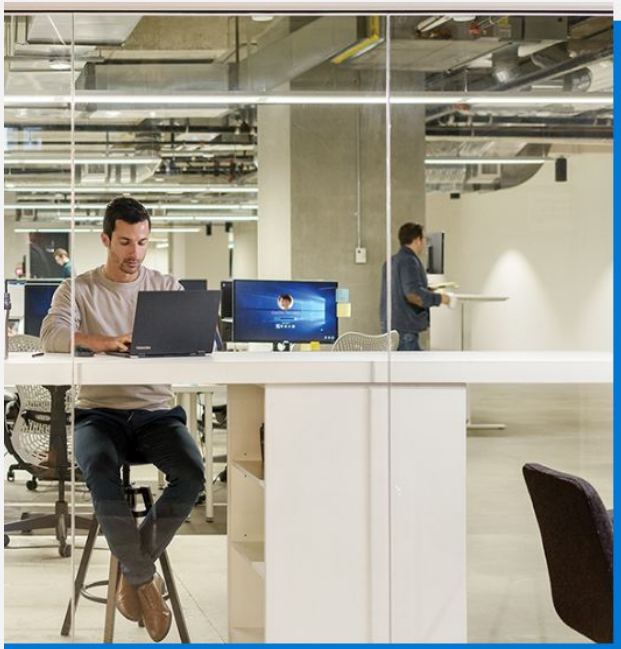
Using Kerberos for Authentication Relay Attacks

Posted by James Forshaw, Project Zero

This blog post is a summary of some research I've been doing into relaying Kerberos authentication in Windows domain environments. To keep this blog shorter I am going to assume you have a working knowledge of Windows network authentication, and specifically Kerberos and NTLM. For a quick primer on Kerberos see this page which is part of Microsoft's Kerberos extension documentation or you can always read RFC4120.

https://googleprojectzero.blogspot.com/2021/10/using-kerberos-for-authentication-relay.html

The Fallout of the Research



Research Threat intelligence Attacker techniques, tools, and infrastructure · 8 min read

Detecting and preventing privilege escalation attacks leveraging Kerberos relaying (KrbRelayUp)

By Microsoft Threat Intelligence

https://www.microsoft.com/en-us/security/blog/2022/05/25/detecting-and-preventing-privilege-escalation-attacks-leveraging-kerberos-relaying-krbrelayup/

What Can You Do About It?

Check the Guidelines from the Vendor



Microsoft | MSRC Report an issue Customer guidance Engage Who we are Blogs Acknowledgments All Microsoft

Microsoft Security Servicing Criteria for Windows

Our commitment to protecting customers from vulnerabilities in our software, services, and devices includes providing security updates and guidance that address vulnerabilities when they are reported to Microsoft. We also want to be transparent with security researchers and our customers in our approach. This document helps to describe the criteria the Microsoft Security Response Center (MSRC) uses to determine whether a reported vulnerability affecting up-to-date and currently supported versions of Windows may be addressed through servicing or in the next version of Windows. For vulnerabilities in Windows, servicing takes the form of a security update or applicable guidance, most commonly released on Update Tuesday (the second Tuesday of each month).

Security Servicing Criteria

The criteria used by Microsoft when evaluating whether to provide a security update or guidance for a reported vulnerability involves answering two key questions:

1. Does the vulnerability violate the goal or intent of a security boundary or a security feature?
2. Does the severity of the vulnerability meet the bar for servicing?

https://www.microsoft.com/en-us/msrc/windows-security-servicing-criteria

Do More Research and Push Back

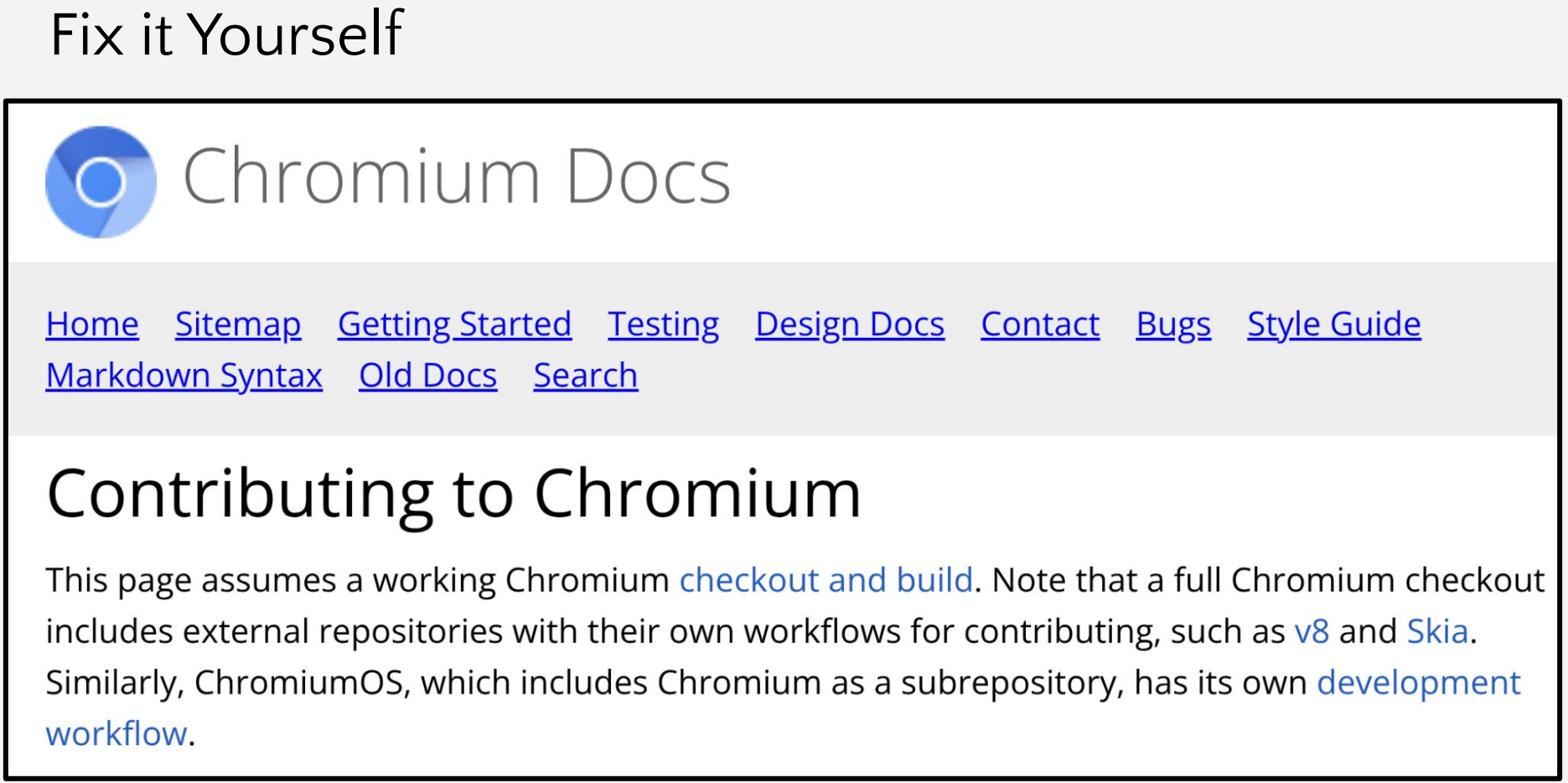


More Research



Relaxing

Fix it Yourself



Find Alternative Reporting Channels

Pwn2Own

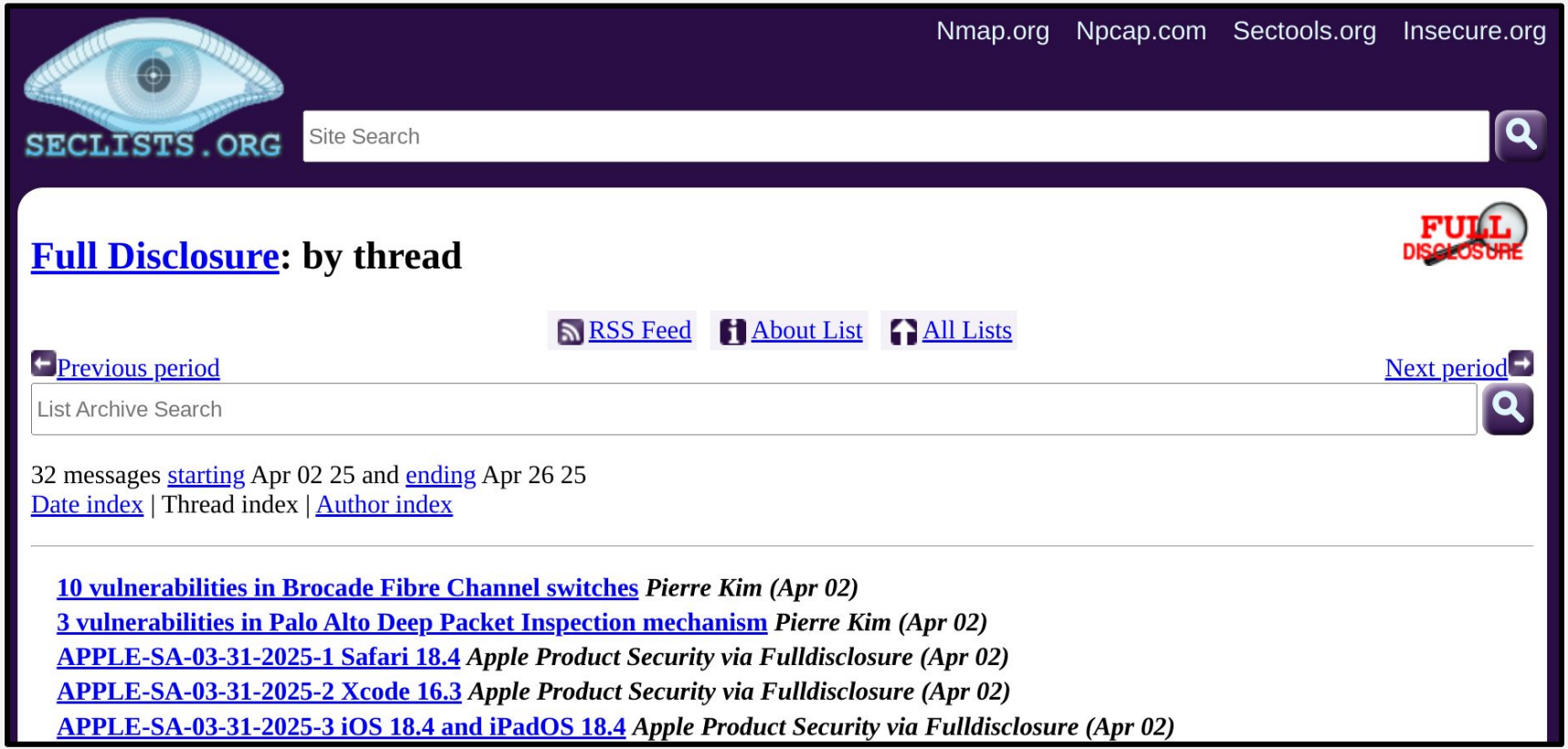
7 languages

Article Talk Read Edit View history Tools

From Wikipedia, the free encyclopedia

Pwn2Own is a computer hacking contest held annually at the CanSecWest security conference.[1] First held in April 2007 in Vancouver,[2] the contest is now held twice a year,[3] most recently in March 2024.[4] Contestants are challenged to exploit widely used software[5] and mobile devices with previously unknown vulnerabilities.[6] Winners of the contest receive the device that they exploited and a cash prize.[7] The Pwn2Own contest serves to demonstrate the vulnerability of devices and software in widespread use while also providing a checkpoint on the progress made in security since the previous year.

Ahem, Full Disclosure, or at least a Blog/Conference



Why you SHOULD Care!

- You can publish the full details of the issue
  - Caveat: in most cases.
- Drive product security improvements, even if the bug not fixed.
- The bug might be useful in a different environment.
- It might lead to a better bug.
- Might improve your job opportunities
  - Project Zero loves a good bug write up
- Kudos!

Thanks, any Questions?